

ABANGCEBU AI — SPRINT 1 CORE INFRASTRUCTURE

User Registration Workflow & Data Contract Specification

Zero-Trust Identity, PKCE Verification Lifecycle, Triple-Firewall Anti-Privilege Escalation & Routing Matrix

Jira Reference: SCRUM-56 (Sprint 1)

Database Foundation: SCRUM-54 (PostgreSQL 15+)

Status: **APPROVED / PRODUCTION-READY**

Lead Architect: Squad Lead Orchestrator

Senior Engineer: Senior Fullstack Engineer

Security Auditor: Senior Dev Auditor

Repository Artifact: docs/auth-registration-spec.md • TypeScript Contracts: src/types/auth.ts

1. Purpose and Source Basis

In Metro Cebu's rental ecosystem, finding reliable accommodation is severely compromised by unverified social media postings, inaccurate coordinates, hidden utility surcharges, and rampant reservation deposit scams. Property owners conversely struggle with repetitive unqualified inquiries. The AbangCebu AI user registration framework establishes a secure, zero-trust gateway for all platform actors.

This technical specification establishes the end-to-end registration workflow, input validation rules, role boundaries, PKCE email verification lifecycle, and API data contracts. It derives directly from foundational project specifications:

Foundation Document	Focus Area	Concrete Architectural Input & Constraints
docs/what-is-abangcebu-ai.md	Product Vision	Defines Finders (Renters) and Landlords (Listers) . Unauthenticated exploration is permitted, but accessing verified landlord phone numbers, saving favorites, and publishing listings strictly requires authenticated accounts.
docs/renter-persona.md	User Experience	Defines student ("Mika") and young professional behaviors: mobile-first, zero-friction registration, landmark selection (preferredLandmark e.g. CIT-U, USC, IT Park), and anti-scam deposit warnings.
docs/users-and-profiles-schema.md	Database Schema	Enforces strict Auth/Profile separation (auth.users 1:1 public.profiles), kyc_verifications anti-scam trust layer, and public.handle_new_user() trigger.
docs/rbac-matrix.md & rls-policies.md	Security Boundaries	Mandates that admin roles can never be self-registered. Governs that Landlords cannot publish listings until their KYC documents are marked verified.

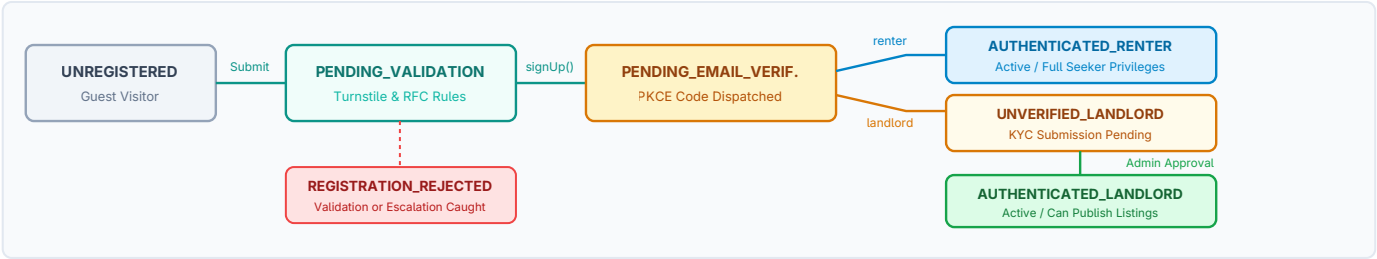
1.1 Permitted vs. Prohibited Self-Registration Roles

- renter (Permitted):** Students, relocators, and professionals seeking rentals. Immediate access to map search, AI assistant, favorites, and landlord contact details upon email confirmation.
- landlord (Permitted):** Property owners and managers. Placed in unverified status upon signup; must complete Philippine Government ID KYC verification before listings can be approved.
- admin (Strictly Prohibited):** Platform moderators and operators. Never registerable via public endpoints. Any attempt to supply role: 'admin' is rejected at API level and clamped to 'renter' by database triggers.

Sprint 1 Iron Rule: Purely foundational specifications, database triggers, types, and backend contracts. Zero premature frontend JSX form widgets or UI feature components.

2. Registration State Machine & Lifecycle

An account transitions through deterministic states from guest access to verified active status:



2.1 State Transition Matrix

Source State	Trigger / Event	Guard / Condition	Target State	System Actions & Side Effects
UNREGISTERED	Submit Form	Valid JSON syntax	PENDING_VALIDATION	Route handler receives payload; starts security pipeline.
PENDING_VALIDATION	Turnstile / Rate Check	Token invalid or >5 requests/hr	REGISTRATION_REJECTED	Returns HTTP 403 or 429; logs security telemetry.
PENDING_VALIDATION	Role Firewall Check	role === 'admin'	REGISTRATION_REJECTED	Returns HTTP 403 (PRIVILEGE_ESCALATION_ATTEMPT).
PENDING_VALIDATION	Field Syntax Check	Password weak or phone invalid	REGISTRATION_REJECTED	Returns HTTP 422 with detailed field error descriptors.
PENDING_VALIDATION	Supabase signUp()	Payload fully valid	PENDING_EMAIL_VERIF.	Creates auth.users; trigger creates public.profiles; dispatches PKCE email.
PENDING_EMAIL_VERIF.	Click Email Link	PKCE code valid, role = 'renter'	AUTHENTICATED_RENTER	exchangeCodeForSession() sets secure cookies; redirects to /search.
PENDING_EMAIL_VERIF.	Click Email Link	PKCE code valid, role = 'landlord'	UNVERIFIED_LANDLORD	Sets secure cookies; forces redirect to /landlord/onboarding (KYC prompt).
UNVERIFIED_LANDLORD	Upload Philippine ID	Valid ID type & storage URL	UNVERIFIED_LANDLORD	Inserts row into public.kyc_verifications (status = 'pending').
UNVERIFIED_LANDLORD	Admin KYC Review	Admin approves document	AUTHENTICATED_LANDLORD	Updates KYC status to 'verified'; unlocks active listing publication.
Any Active State	Admin Moderation	TOS breach or scam reported	ACCOUNT_SUSPENDED	Sets profiles.is_suspended = true; revokes active session tokens.

3. Data Contract & Schemas

3.1 Endpoint Contract: POST /api/auth/register

Field	Type	Required?	Validation Rule	Description
email	string	Yes	RFC 5322 regex, max 254 chars	Normalized to lowercase. Checked for existing account.
password	string	Yes	8-72 chars, min 3 of 4 classes	NIST SP 800-63B compliant. Disallows leading/trailing spaces.
role	RegisterableRole	Yes	'renter' 'landlord'	Strictly self-assignable roles. Prohibits 'admin'.
fullName	string	Yes	2-100 chars, letters & spaces	Legal name. Sanitized of control characters and HTML tags.
phoneNumber	string	Optional	^(?:\+639 09)\d{9}\$	Philippine mobile. Normalized to +639XXXXXXXX.
preferredLandmark	string	Optional	Max 100 chars	Initial focus campus or workplace (e.g. "USC Talamban", "IT Park").
turnstileToken	string	Optional*	Cloudflare Turnstile token	Bot prevention verification token (mandatory in production).

3.2 TypeScript Contracts (src/types/auth.ts)

```
export type RegisterableRole = Exclude<UserRole, 'admin'>; // 'renter' | 'landlord'

export interface RegisterPayload {
  email: string;
  password: string;
  role: RegisterableRole;
  fullName: string;
  phoneNumber?: string;
  preferredLandmark?: string;
  turnstileToken?: string;
}

export interface RegisterSuccessResponse {
  success: true;
  data: {
    user: RegisteredUserSummary;
    requiresEmailVerification: boolean;
    redirectUrl: string;
  };
  message: string;
}

export interface AuthErrorResponse {
  success: false;
  error: {
    code: AuthErrorCode;
    message: string;
    details?: AuthFieldError[];
  };
}
```

4. Validation & Security Rules

4.1 Triple-Firewall Anti-Privilege Escalation

- **Tier 1 — TypeScript & Contract Layer:** RegisterableRole = Exclude<UserRole, 'admin'>. Client form schemas reject the string 'admin' at compile time and input validation time.
- **Tier 2 — Next.js Server Route Handler / Action:** Server asserts payload.role in ['renter', 'landlord']. If 'admin' is detected, execution halts immediately with HTTP 403 PRIVILEGE_ESCALATION_ATTEMPT and a security audit log is written.
- **Tier 3 — PostgreSQL Trigger & RLS Layer:** public.handle_new_user() unconditionally coerces any non-landlord role to 'renter'. RLS policies permanently prevent self-modification of the role column on public.profiles.

4.2 Password Policy & Philippine Phone Normalization

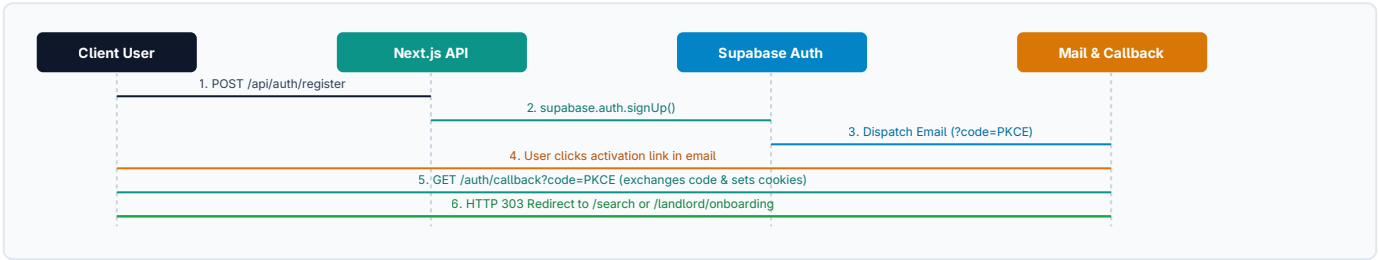
- **NIST SP 800-63B Password Policy:** 8-72 characters; must satisfy at least 3 of 4 classes: Uppercase, Lowercase, Digits, Symbols.
- **Philippine Phone Normalization:** Matches ^(?:\+639|09)\d{9}\$; normalizes 09XXXXXXXX to canonical E.164 +639XXXXXXXX (13 chars). Complies with PostgreSQL check constraint phone_format_check.
- **Anti-Enumeration:** Uniform timing and obfuscated responses prevent scraping registered user emails.

3.3 Error Taxonomy Table

Error Code	Status	Category	Trigger Condition	Client Facing Message
VALIDATION_ERROR	422	Input Validation	One or more payload fields fail schema check	The submitted registration data is invalid.
INVALID_EMAIL_FORMAT	422	Input Validation	Email fails RFC 5322 regex check	Please enter a valid email address.
WEAK_PASSWORD	422	Input Validation	Password <8 chars or <3 character classes	Password must be 8-72 chars with upper, lower, number, or symbol.
INVALID_PHONE_NUMBER	422	Input Validation	Phone does not match Philippine mobile pattern	Phone number must be a valid PH mobile (09XXXXXXXX).
INVALID_ROLE	422	Input Validation	Role not in ('renter', 'landlord')	Selected account type is invalid.
MISSING_REQUIRED_FIELD	422	Input Validation	Missing email, password, role, or fullName	Required registration field is missing.
PRIVILEGE_ESCALATION_ATTEMPT	403	Security & Abuse	role: 'admin' detected in payload	Administrative accounts cannot be self-registered.
RATE_LIMIT_EXCEEDED	429	Security & Abuse	Exceeded 5 registration submissions per hour/IP	Too many registration attempts. Please try again later.
CAPTCHA_VERIFICATION_FAILED	403	Security & Abuse	Turnstile token validation failed or absent	Security check failed. Please refresh the page and try again.
EMAIL_ALREADY_REGISTERED	409	Security & Abuse	Email exists in auth.users	An account with this email address already exists.
ACCOUNT_SUSPENDED	403	Security & Abuse	Profile flag is_suspended = true	This account has been suspended by administration.
CONFIRMATION_CODE_EXPIRED	410	Lifecycle	PKCE confirmation token clicked after 24h	The activation link has expired. Please request a new one.
CONFIRMATION_CODE_INVALID	400	Lifecycle	Malformed or previously used code	The activation link is invalid or has already been used.
ALREADY_CONFIRMED	200	Lifecycle	Exchange attempted on verified user	Your email is already verified. Please sign in.
DATABASE_TRIGGER_ERROR	500	Internal	handle_new_user() trigger fails on insert	An error occurred while creating your user profile.
INTERNAL_AUTH_ERROR	500	Internal	Supabase Auth failure or network crash	An unexpected authentication error occurred. Please try again.

5. Email Verification & PKCE Flow

AbangCebu AI implements **PKCE (Proof Key for Code Exchange)** using `@supabase/ssr`. The browser receives a short-lived authorization code that is exchanged on the server, establishing secure `httpOnly`, `SameSite=Lax` session cookies.



5.1 Open-Redirect Defense

The `/auth/callback` route validates the `next` parameter against an explicit whitelist (`/search`, `/onboarding/renter`, `/landlord/onboarding`, `/account/profile`, `/renter/favorites`). Any external or protocol-relative URI is rejected.

6. Post-Registration Routing Matrix

Role	Email Confirmed?	KYC Status	Target Route	Viewport Presentation & Call to Action
Any	No	N/A	<code>/auth/verify-request</code>	"Check your inbox to activate your account." Resend link button available.
Renter	Yes	N/A	<code>/search</code> (or <code>/onboarding/renter</code>)	Interactive Metro Cebu map. Welcomes renter, highlights nearby campus/work pins, prompts landmark preference.
Landlord	Yes	unsubmitted	<code>/landlord/onboarding</code>	Mandatory KYC Banner: "Submit Philippine Government ID to activate listing publishing."
Landlord	Yes	pending	<code>/landlord/dashboard</code>	Informational: "KYC under review (12-24h). Draft listings remain hidden until approved."
Landlord	Yes	verified	<code>/landlord/dashboard</code>	Full Landlord Studio active. Verified owner badge displayed; listing publishing active.
Landlord	Yes	rejected	<code>/landlord/onboarding?retry=true</code>	Alert: "KYC verification was rejected. Review reason and resubmit valid ID."
Any	Any	N/A (is_suspended)	<code>/auth/suspended</code>	Notice: "Account suspended by administration. Contact support@abangcebu.com."

7. Database Trigger Integration (handle_new_user)

The PostgreSQL trigger `public.handle_new_user()` executes `AFTER INSERT ON auth.users`. It parses `raw_user_meta_data`, coerces roles, cleans full names, normalizes phone numbers, and inserts into `public.profiles`. Because it executes inside the user insertion transaction, failures trigger an atomic rollback, ensuring zero orphaned auth records.

8. Deliverables & Verification Sign-Off

- ✔ **TypeScript Authentication Types:** `src/types/auth.ts` (All interfaces, enums, rules, and validators implemented).
- ✔ **Types Index Export:** `src/types/index.ts` cleanly exports `* from './auth'` and `* from './database'`.
- ✔ **Markdown Specification:** `docs/auth-registration-spec.md` created with complete architecture and data contracts.
- ✔ **TypeScript Compilation:** `pnpm exec tsc --noEmit` passed with **0 errors**.
- ✔ **Sprint 1 Iron Rule:** Zero premature frontend JSX form components created.